Cyber Security

Module 5: Technological Aspects
of Cyber Security

Exam-Oriented Study Notes

Course Faculty: **Prof. Basabdatta Chakraborty**

Compiled by **Amitendu** and **Claude**

BCA, MAKAUT

Contents

1 Firewalls **2**
1.1 Working Principle . . . 2
1.2 Types of Firewalls . . . 2
1.3 Hardware, Software and Host-Based . . . 2
1.4 DMZ Architecture . . . 2
1.5 Advantages and Limitations . . . 3

2 IDS and IPS **3**
2.1 IDS vs IPS . . . 4
2.2 IDS/IPS vs Firewall . . . 4

3 Virtual Private Networks (VPN) **4**
3.1 Working . . . 4
3.2 Types of VPN . . . 5
3.3 Benefits and Limitations . . . 5

4 Security Protocols: SSL, TLS and IPsec **5**
4.1 SSL and TLS . . . 5
4.1.1 TLS Handshake (TLS 1.2, simplified) . . . 6
4.1.2 TLS 1.2 vs TLS 1.3 . . . 6
4.2 IPsec (Internet Protocol Security) . . . 7
4.3 SSL/TLS vs IPsec . . . 7

5 Intrusion Detection Systems **8**
5.1 Types of IDS . . . 8
5.2 Detection Methods . . . 8
5.3 Alerts: Accuracy of Detection . . . 8
5.4 Limitations . . . 8

6 Honeypots **9**
6.1 Types of Honeypots . . . 9
6.2 Advantages and Disadvantages . . . 9

7 Multi-Factor Authentication (MFA) **10**
7.1 Authentication Factors . . . 10
7.2 Common MFA Methods . . . 10
7.3 Benefits and Limitations . . . 10

8 Emerging Technologies in Cyber Security **11**
8.1 Artificial Intelligence (AI) and Machine Learning . . . 11
8.2 Blockchain in Security . . . 11
8.3 Quantum Cryptography . . . 12
8.3.1 QKD: The BB84 Idea . . . 12
8.4 Other Emerging Trends (Brief) . . . 13

9 Quick Revision Sheet **14**

1 Firewalls

Definition

A **firewall** is a hardware or software security system that monitors and controls incoming and outgoing network traffic according to a set of **security rules**, forming a barrier between a trusted internal network and an untrusted network such as the Internet.

1.1 Working Principle

Each packet is compared with an ordered list of rules (an **Access Control List**). The first matching rule decides whether the packet is **allowed, denied or dropped**. Good practice is a **default deny** policy: anything not explicitly allowed is blocked.

Rule	Source	Destination	Port	Action
1	Any	Web server	TCP 443	Allow
2	Internal LAN	Any	TCP 80, 443	Allow
3	Admin PC	Web server	TCP 22	Allow
4	Any	Any	Any	**Deny (default)**

1.2 Types of Firewalls

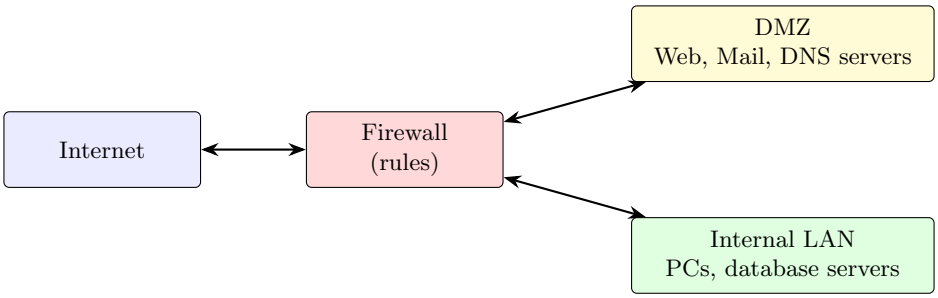
Type	How it Works	Remark
Packet filtering	Checks each packet's source and destination IP, port and protocol	Fast, simple; no knowledge of connection state
Stateful inspection	Tracks the state of connections (e.g. TCP handshake) and allows only valid replies	More secure; the standard today
Circuit-level gateway	Verifies that a session is legitimate (handshake) and then relays it	Works at the session level
Proxy / Application gateway	Acts as an intermediary; inspects application data (HTTP, FTP)	Strong filtering but slower
Next-Generation Firewall (NGFW)	Stateful inspection plus deep packet inspection, IPS, application awareness and malware filtering	Used in modern enterprises
Web Application Firewall (WAF)	Protects web apps from SQL injection, XSS and similar attacks	Works at Layer 7 for HTTP/HTTPS

1.3 Hardware, Software and Host-Based

Network (hardware) firewall protects a whole network at its edge; **host-based (software) firewall** runs on one computer (e.g. Windows Defender Firewall, `iptables`); **cloud firewall** is delivered as a service.

1.4 DMZ Architecture

A **DMZ (Demilitarised Zone)** is a separate network segment that holds public-facing servers (web, mail, DNS). If a DMZ server is compromised, the attacker still cannot directly reach the internal LAN.



1.5 Advantages and Limitations

Advantages	Limitations
Blocks unauthorised access and unwanted ports	Cannot stop attacks that come from **inside** the network
Enforces network security policy centrally	Cannot inspect encrypted traffic without decryption
Logs traffic for auditing	Cannot prevent social engineering or malware brought by users
Hides internal network structure (with NAT)	Misconfigured rules create holes; single point of failure

Exam Tip

Always include the **rule table with a default-deny rule**, the list of firewall types, and the DMZ diagram. A comparison of packet filtering and stateful inspection is a popular short question.

Practice Questions

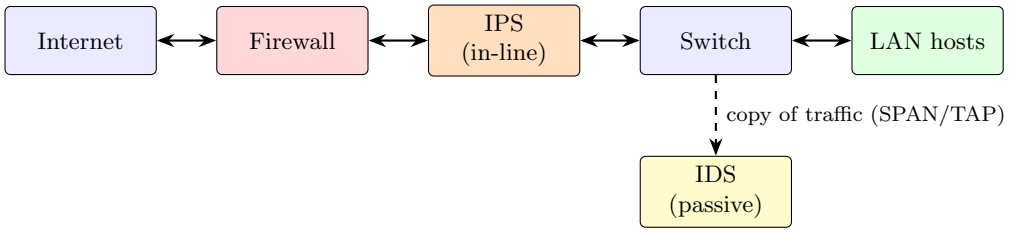
Short Answer: (1) Define firewall. (2) What is a DMZ? (3) Differentiate stateless and stateful firewalls.

Long Answer: (4) Explain the types of firewalls with their advantages and limitations. (5) Describe a DMZ-based network design with a diagram.

2 IDS and IPS

Definitions

An **Intrusion Detection System (IDS)** monitors network or system activity for malicious behaviour or policy violations and **raises alerts**.
An **Intrusion Prevention System (IPS)** does the same but is placed **in-line** and can **automatically block** the malicious traffic.



2.1 IDS vs IPS

Basis	IDS	IPS
Function	Detects and alerts	Detects and **prevents / blocks**
Placement	Out-of-band; receives a copy of traffic	In-line; all traffic passes through it
Action	Passive (log, alert)	Active (drop packets, block IP, reset connection)
Impact on traffic	None; no delay	May add latency; failure can interrupt traffic
False positives	Only causes extra alerts	Can block legitimate traffic
Examples	Snort (IDS mode), Zeek, OSSEC	Snort or Suricata (IPS mode), commercial NGIPS

2.2 IDS/IPS vs Firewall

A firewall mainly allows or blocks traffic using **rules on addresses and ports**; an IDS/IPS analyses **packet contents and behaviour** to spot attacks (exploits, scans, malware). They are **complementary**, so both are used together (defence in depth).

Exam Tip

The key phrase is: **IDS = detect and alert (passive); IPS = detect and block (active, in-line)**. Draw the placement diagram to show the difference.

Practice Questions

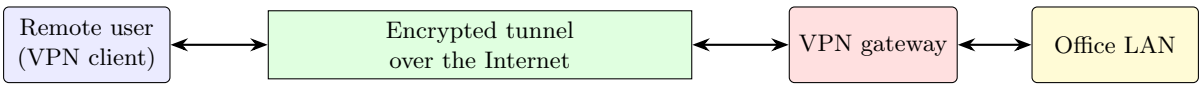
Short Answer: (1) Expand IDS and IPS. (2) Why can an IPS cause problems if it fails? (3) Name two open-source IDS/IPS tools.

Long Answer: (4) Differentiate IDS and IPS with a placement diagram. (5) Compare firewall and IDS/IPS.

3 Virtual Private Networks (VPN)

Definition

A **VPN** creates a secure, encrypted connection (a **tunnel**) over a public network such as the Internet, so that remote users or sites can communicate as if they were on the same private network.



3.1 Working

1. The user connects with a VPN client and **authenticates** (password, certificate, MFA).
2. The two ends agree on **encryption keys and algorithms**.
3. Original packets are **encapsulated** (tunnelling) and **encrypted**.
4. Encrypted packets travel through the Internet; unreadable to outsiders.
5. The VPN gateway **decrypts** them and forwards them to the internal network.

3.2 Types of VPN

Type	Description	Use
Remote-access VPN	Individual user connects to the company network	Work from home, travelling staff
Site-to-site VPN	Two networks (branch and head office) connected through gateways	Linking offices securely
SSL/TLS VPN	Uses TLS, often through a browser or light client	Easy access to selected applications
IPsec VPN	Works at the network layer; full network access	Corporate gateways

Common VPN protocols: IPsec (with IKE), OpenVPN, WireGuard, L2TP/IPsec, SSTP. **PPTP** is obsolete and insecure.

Full tunnel sends all traffic through the VPN; **split tunnel** sends only company traffic through it.

3.3 Benefits and Limitations

Benefits	Limitations
Confidentiality and integrity on public networks	Slower speed due to encryption overhead
Secure remote access and cost saving over leased lines	Depends on strong authentication; stolen credentials defeat it
Hides the user's real IP address from sites	VPN provider (or gateway) can see traffic metadata
Protects on public Wi-Fi	A compromised device on VPN can bring malware inside

Exam Tip

Mention the three key ideas: **tunnelling, encryption, authentication**. Give both types (remote-access and site-to-site) with a diagram.

Practice Questions

Short Answer: (1) What is tunnelling? (2) Differentiate remote-access and site-to-site VPN. (3) Why is PPTP not recommended?

Long Answer: (4) Explain the working, types and benefits of a VPN.

4 Security Protocols: SSL, TLS and IPsec

4.1 SSL and TLS

Definition

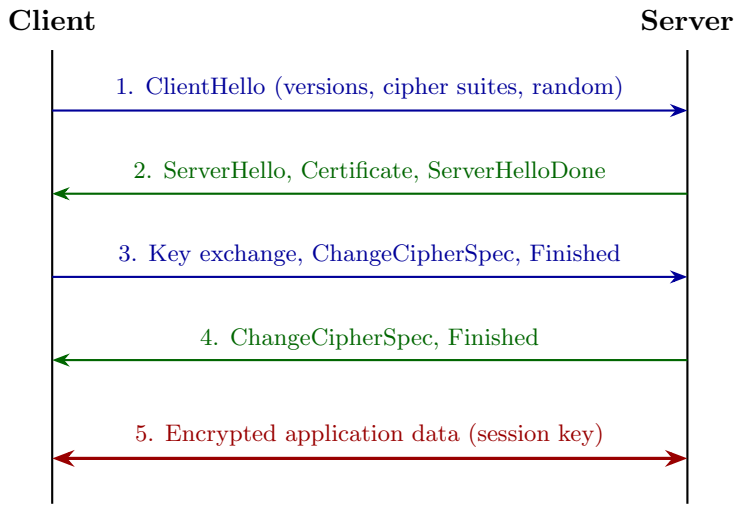
SSL (Secure Sockets Layer) and its successor **TLS (Transport Layer Security)** are cryptographic protocols that secure communication between a client and a server over a network, working above the transport layer (TCP). **HTTPS** is HTTP carried over TLS (port 443).

History: SSL 2.0 and 3.0 are **deprecated**; TLS 1.0 and 1.1 are also deprecated; **TLS 1.2** is widely used and **TLS 1.3** (2018) is the latest and most secure. Today, "SSL" usually means TLS in practice.

Services provided:

- **Confidentiality:** data encrypted with a symmetric **session key** (e.g. AES).
- **Integrity:** message authentication (MAC / AEAD) detects tampering.
- **Authentication:** the server (and optionally the client) proves identity using **X.509 digital certificates** issued by a trusted **Certificate Authority (CA)**.

4.1.1 TLS Handshake (TLS 1.2, simplified)



1. **ClientHello:** client sends supported TLS versions, cipher suites and a random number.
2. **ServerHello and Certificate:** server chooses parameters and sends its certificate (with its public key).
3. **Verification and key exchange:** client checks the certificate (trusted CA, validity, domain name), then both sides derive a shared **session key**.
4. **Finished messages** confirm that the handshake was not tampered with.
5. **Secure data transfer** begins using fast symmetric encryption.

This is the **hybrid approach**: asymmetric cryptography to set up keys, symmetric cryptography for the data.

4.1.2 TLS 1.2 vs TLS 1.3

Feature	TLS 1.2	TLS 1.3
Handshake	2 round trips	1 round trip (faster)
Old weak algorithms (RC4, SHA-1, static RSA key exchange)	Possible	Removed
Forward secrecy	Optional	Mandatory (ephemeral Diffie-Hellman)
Security	Good if well configured	Stronger and simpler

4.2 IPsec (Internet Protocol Security)

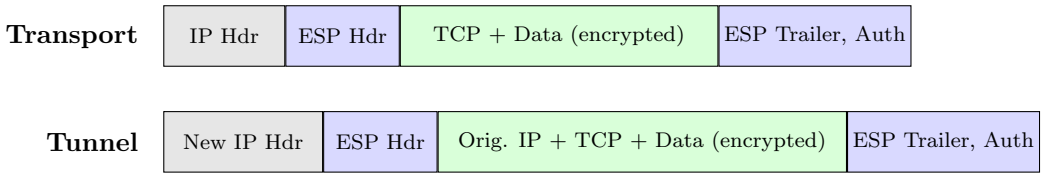
Definition

IPsec is a suite of protocols that secures communication at the **network layer** by authenticating and encrypting each IP packet. It protects **all** traffic between two hosts or gateways, whatever the application.

Main components:

- **AH (Authentication Header):** provides integrity and authentication of the packet; **no encryption**.
- **ESP (Encapsulating Security Payload):** provides **encryption** plus integrity and authentication. Most commonly used.
- **IKE (Internet Key Exchange):** negotiates algorithms and keys and creates the **Security Association (SA)**, a one-way agreement describing how traffic is protected.

Modes of operation:



- **Transport mode:** only the payload is protected; original IP header stays. Used **host-to-host**.
- **Tunnel mode:** the **entire original packet** is protected and wrapped in a new IP header. Used **gateway-to-gateway** (site-to-site VPN).

Facts to remember: ESP uses IP protocol number **50**, AH uses **51**, and IKE uses UDP port **500** (4500 for NAT traversal).

4.3 SSL/TLS vs IPsec

Basis	SSL/TLS	IPsec
Layer	Above transport (application/session level)	Network layer
Protects	Individual application connections (e.g. web)	All IP traffic between endpoints
Setup	Easy; works through browsers	Needs client or gateway configuration
Authentication	Mainly server certificates	Pre-shared keys or certificates for both sides
Typical use	HTTPS, email, SSL VPN	Site-to-site VPN, remote-access VPN

Exam Tip

Draw the **TLS handshake diagram** and explain the hybrid use of asymmetric and symmetric keys. For IPsec, remember: **AH = integrity only, ESP = encryption + integrity; transport vs tunnel modes**.

Practice Questions

Short Answer: (1) What is the role of a Certificate Authority? (2) Differentiate AH and ESP. (3) Which TLS version is the most secure?

Long Answer: (4) Explain the SSL/TLS handshake with a diagram. (5) Explain IPsec, its components and modes. (6) Compare TLS and IPsec.

5 Intrusion Detection Systems

An IDS has three main parts: **sensors** (collect traffic or logs), an **analysis engine** (matches data against rules or models) and a **management console** (alerts, reports, tuning).

5.1 Types of IDS

Type	Description	Examples
Network-based (NIDS)	Monitors traffic passing through a network segment; placed at key points	Snort, Suricata, Zeek
Host-based (HIDS)	Runs on a single host; watches logs, system calls, file integrity and registry changes	OSSEC, Wazuh, Tripwire
Hybrid	Combines NIDS and HIDS for wider visibility	Many commercial products

5.2 Detection Methods

Method	Idea	Strength	Weakness
Signature-based	Compares activity with a database of known attack patterns	Accurate for known attacks, few false alarms	Cannot detect new (zero-day) attacks; needs updates
Anomaly-based	Learns normal behaviour and flags deviations	Can detect unknown attacks	More false positives; needs training period
Stateful protocol analysis	Compares activity with expected protocol behaviour	Finds protocol misuse	Resource intensive

5.3 Alerts: Accuracy of Detection

	Attack Present	No Attack
Alert raised	True Positive (correct detection)	**False Positive** (false alarm)
No alert	**False Negative** (missed attack, dangerous)	True Negative (correct)

Too many false positives cause **alert fatigue**, while false negatives let real attacks pass. **Tuning** the rules balances both.

5.4 Limitations

Cannot inspect encrypted traffic without decryption, needs constant rule updates and skilled analysts, can be evaded by fragmentation or obfuscation, and a flood of alerts can hide a real attack. Alerts are usually collected in a **SIEM** for correlation.

Exam Tip

Learn the **signature vs anomaly** comparison and the **four outcomes** (TP, FP, TN, FN). The false-positive/false-negative matrix is often asked.

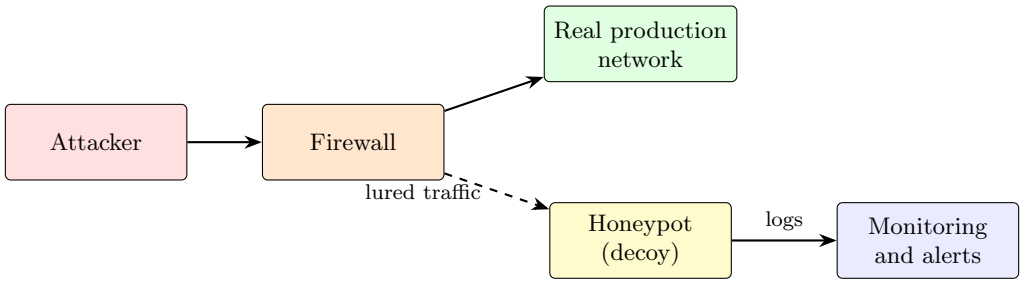
Practice Questions

Short Answer: (1) Differentiate NIDS and HIDS. (2) What is a false negative? (3) Why can anomaly-based IDS detect zero-day attacks?
Long Answer: (4) Explain the types and detection methods of IDS with examples.

6 Honeypots

Definition

A **honeypot** is a decoy computer system or service deliberately set up to **attract and trap attackers**. It has no real business value, so **any** interaction with it is suspicious. It is used to detect attacks, distract attackers and study their methods.



6.1 Types of Honeypots

Type	Description	Remark
Low-interaction	Emulates a few services (fake ports)	Easy and safe; limited information
High-interaction	Real systems with real OS and services	Rich data about attackers; higher risk and effort
Production honeypot	Placed inside an organisation to detect intruders early	Improves detection
Research honeypot	Used by researchers to study new attacks and malware	Collects detailed intelligence

A **honeynet** is a network of multiple honeypots. A **honeytoken** is fake data (a fake password file or database record) that raises an alert when used. Example tools: Cowrie, Honeyd, Dionaea.

6.2 Advantages and Disadvantages

Advantages	Disadvantages
Very few false positives (no legitimate use)	Sees only attacks that target it
Reveals attacker tools, techniques and motives	Risk: if compromised, it may be used to attack the real network
Small data volume, easy analysis	Needs isolation, monitoring and skilled staff
Diverts attackers from real systems	Skilled attackers may recognise a honeypot

Remember

A honeypot is a **detection and research tool**, not a replacement for firewalls or an IDS. It must be **isolated** from production systems, and legal and ethical aspects (such as entrapment and privacy) should be considered.

Exam Tip

Define it as a **decoy**, give the **low vs high interaction** difference, and note the key risk of it being used as a pivot.

Practice Questions

Short Answer: (1) What is a honeypot? (2) What is a honeynet? (3) Why does a honeypot produce few false positives?
Long Answer: (4) Explain honeypots, their types, advantages and disadvantages.

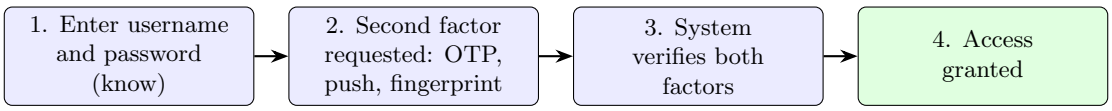
7 Multi-Factor Authentication (MFA)

Definition

Multi-Factor Authentication (MFA) requires a user to prove their identity using **two or more different categories** of evidence before access is granted. **Two-Factor Authentication (2FA)** is the case with exactly two factors. Using two passwords is **not** MFA, because both are the same factor type.

7.1 Authentication Factors

Factor	Category	Examples
Something you **know**	Knowledge	Password, PIN, security question
Something you **have**	Possession	OTP from phone, authenticator app, smart card, hardware security key
Something you **are**	Inherence	Fingerprint, face, iris, voice
Somewhere you **are**	Location (contextual)	GPS or IP location, trusted network



7.2 Common MFA Methods

Method	Description	Security Note
SMS OTP	One-time code sent by text	Weakest; vulnerable to SIM swap and interception
TOTP app	Time-based code generated on the phone (e.g. Google Authenticator)	Better; works offline; can still be phished
Push notification	Approve or deny on a trusted device	Convenient; risk of **MFA fatigue** (spamming prompts)
Hardware key (FIDO2/WebAuthn)	Physical USB/NFC key or passkey	**Phishing-resistant**; strongest option
Biometrics	Fingerprint, face recognition	Convenient; cannot be changed if compromised

7.3 Benefits and Limitations

- **Benefits:** a stolen password alone is not enough; sharply reduces account takeover; helps meet compliance (banking, e-commerce).

- **Limitations:** extra effort for users; losing the second device causes lockout; phishing kits can relay codes in real time; SMS-based codes are weak.
- **Adaptive (risk-based) MFA** asks for extra factors only when the login looks unusual (new device or location).

Exam Tip

State the three factor categories with examples and say clearly that MFA needs **different categories**. Mention that **hardware keys / passkeys are phishing-resistant**, while SMS OTP is weakest.

Practice Questions

Short Answer: (1) Define MFA. (2) Is a password plus a security question MFA? Why? (3) What is a SIM swap attack?

Long Answer: (4) Explain authentication factors and MFA methods with their security strengths and weaknesses.

8 Emerging Technologies in Cyber Security

8.1 Artificial Intelligence (AI) and Machine Learning

AI in defence:

- **Anomaly detection:** models learn normal behaviour of users and networks and flag unusual activity (UEBA).
- **Malware and phishing detection:** classify files, URLs and emails using learned patterns, even for unseen variants.
- **Automation:** faster triage and response through SIEM/SOAR, threat hunting and alert prioritisation.
- **Predictive analysis:** spotting vulnerabilities and likely attack paths.

AI as a threat:

- More convincing phishing and **deepfake** voice or video for social engineering.
- **Adversarial attacks** that fool models (poisoned training data, evasion inputs).
- Automated vulnerability discovery and attack scaling by attackers.

Challenges: false positives, need for quality data, lack of explainability, and the need for human oversight.

8.2 Blockchain in Security

Idea

A **blockchain** is a distributed ledger of blocks linked by **cryptographic hashes**. Each block stores the hash of the previous block, so changing old data breaks the chain. Nodes agree on new blocks through a **consensus mechanism**, so there is no single point of control.

Security Use	How Blockchain Helps
Tamper-evident logs and audit trails	Records cannot be altered silently
Decentralised identity	Users control their own credentials; reduces central password databases
Data integrity and provenance	Verify that documents, software or supply-chain records are unchanged
IoT security	Authenticate devices and record firmware updates without a central server
Secure transactions	Digital signatures and consensus protect payments

Limitations: scalability and speed, high energy use for some consensus methods, **loss of private keys is irreversible**, smart-contract bugs, privacy concerns because data is visible, and risks such as a **51% attack** on small networks.

8.3 Quantum Cryptography

Why it matters: a large quantum computer running **Shor's algorithm** could break public-key systems based on factoring or discrete logarithms (**RSA, ECC, Diffie-Hellman**). **Grover's algorithm** speeds up brute-force search, effectively halving the strength of symmetric keys, so **AES-256** is recommended. Attackers may already "**harvest now, decrypt later**" by storing encrypted data today.

There are two different responses:

Basis	Quantum Key Distribution (QKD)	Post-Quantum Cryptography (PQC)
Based on	Laws of quantum physics (photons)	Classical maths problems believed hard even for quantum computers (lattices, hashes)
Hardware	Special optical equipment and fibre or satellite links	Runs on ordinary computers
Purpose	Securely **exchange keys**	Replace RSA/ECC for encryption and signatures
Examples	BB84 protocol	NIST standards: ML-KEM (key exchange), ML-DSA and SLH-DSA (signatures)
Practicality	Limited distance and high cost	Easier to deploy; migration is under way

8.3.1 QKD: The BB84 Idea

1. Alice sends photons carrying random bits, each prepared in a randomly chosen **basis** (rectilinear or diagonal polarisation).
2. Bob measures each photon in a randomly chosen basis.
3. Over a normal channel they **compare only the bases** (not the bit values) and keep the bits where the bases matched; this becomes the **raw key**.
4. They compare a small sample of the key. A high error rate means an **eavesdropper** disturbed the photons, because measuring a quantum state changes it (and quantum states cannot be copied: the **no-cloning theorem**), so the key is discarded.

An interception by Eve typically produces about **25%** errors in the matching-basis bits, which makes her presence detectable.

Remember

QKD only **distributes keys**; the data is then encrypted with a normal cipher such as AES. It also needs an **authenticated** classical channel. For most organisations, the practical step is **migrating to post-quantum algorithms** and building **crypto-agility**.

8.4 Other Emerging Trends (Brief)

- **Zero Trust:** "never trust, always verify" every user and device, regardless of location.
- **XDR / SIEM / SOAR:** unified detection and automated response across endpoints, network and cloud.
- **Cloud and IoT security:** protecting distributed and resource-limited devices.
- **Passwordless authentication (passkeys)** based on public-key cryptography.

Exam Tip

For "emerging technologies", write **uses and limitations** for each of AI, blockchain and quantum. In quantum, clearly differentiate **QKD (physics)** from **post-quantum cryptography (maths)** and name **Shor's algorithm** as the threat to RSA.

Practice Questions

Short Answer: (1) How does AI help in intrusion detection? (2) Why is a blockchain tamper-evident? (3) What is "harvest now, decrypt later"?

Long Answer: (4) Discuss the role of AI in cyber security, including risks. (5) Explain how blockchain can improve security, with limitations. (6) Explain quantum cryptography, QKD and the threat of quantum computing to RSA.

9 Quick Revision Sheet

Topic	Remember
Firewall	Rule-based traffic filter; default deny; types: packet filter, stateful, proxy, NGFW, WAF
DMZ	Separate segment for public servers; protects the internal LAN
IDS vs IPS	IDS detects and alerts (passive); IPS detects and blocks (in-line)
IDS types	NIDS (network), HIDS (host); signature vs anomaly detection
Alert outcomes	TP, FP (false alarm), TN, FN (missed attack)
VPN	Tunnelling + encryption + authentication; remote-access and site-to-site
TLS	Hybrid: certificate and asymmetric key exchange, then symmetric session key; TLS 1.3 is latest
IPsec	Network layer; AH (integrity only), ESP (encryption), IKE; transport vs tunnel mode
Honeypot	Decoy system; low vs high interaction; honeynet; must be isolated
MFA	Different factor types: know, have, are; hardware keys are phishing-resistant
AI in security	Anomaly detection, automation; threats: deepfakes, adversarial attacks
Blockchain	Hash-linked, distributed ledger; tamper-evident logs, decentralised identity
Quantum	Shor breaks RSA/ECC; QKD (BB84) uses physics; PQC uses new maths (ML-KEM, ML-DSA)